Informe de evaluación de controles de confidencialidad

E(Tres Patitos, XEPDB1, 23/10/2026) · ISO/IEC 27001:2022, Anexo A

Simulación. Este informe se generó con resultados simulados de los scripts de verificación, a solicitud del curso, para mostrar cómo se registra y se lee una evaluación. La empresa Tres Patitos es ficticia: ningún dato proviene de una ejecución real.

Empresa (i)	Tres Patitos
Base de datos	XEPDB1 · Oracle Database 21c Express Edition
Fecha (t)	23/10/2026
Auditor	Gloriana Sojo Pereira
Cuenta de verificación	AUDITOR_EXT (solo lectura: CREATE SESSION, SELECT_CATALOG_ROLE, AUDIT_VIEWER)
Scripts aplicados	01_verificacion_controles.sql (PT-00 a PT-15) · 03_pruebas_funcionales.sql (PF-01 a PF-07) · PF-08 en RMAN

1. Resultado

53,5 %

Semáforo Amarillo

5 controles cumplen por completo, 6 cumplen en parte y 4 no cumplen. El riesgo de confidencialidad está controlado solo en parte: la base protege bien la autenticación, el cifrado en reposo y el registro de actividad, pero tiene brechas en control de acceso, segregación de funciones y cifrado de red.

RC(i, t) = (CS1·W1 + ... + CS15·W15) / (W1 + ... + W15). Cada CSk vale 1 si el control observable cumple su criterio de aceptación, 0 si no cumple y 0,5 si cumple en parte. Wk es el puntaje I×P del riesgo más alto que atiende el control. Semáforo: Rojo de 0 a 30 %, Amarillo de 30 a 70 %, Verde de 70 a 100 %.

2. Resultados por control

Control	Valor	Peso	Aporte	Evidencia
CS1 · A5.12 Clasificación de la información	0,5	16	3,7 %	PT-01: 6 de 9 columnas sensibles del inventario están etiquetadas.
CS2 · A5.15 Control de acceso	0	16	0,0 %	PT-02: 4 privilegios directos (JPEREZ, MSOLANO, APP_REPORTES). PF-03: RRHH.EMPLEADOS es legible sin rol por un grant a PUBLIC.
CS3 · A5.16 Gestión de identidades	0,5	15	3,5 %	PT-03: CVARGAS (exfuncionaria) y TEMP_SOPORTE (genérica) abiertas.
CS4 · A5.17 Información de autenticación	1	15	6,9 %	PT-04: 0 filas. PF-02: ORA-28003, contraseña débil rechazada.
CS5 · A5.18 Derechos de acceso	0	16	0,0 %	PT-05: sin capturas de privilegios ni acta de revisión.

Control	Valor	Peso	Aporte	Evidencia
CS6 · A5.33 Protección de registros	0	12	0,0 %	PT-06: ADMIN_BD tiene DBA y AUDIT_ADMIN. PF-07: el DBA creó una política.
CS7 · A8.2 Derechos de acceso privilegiado	0,5	16	3,7 %	PT-07: SOPORTE01 con DBA y APP_REPORTES con SELECT ANY TABLE sin autorización.
CS8 · A8.3 Restricción de acceso a la información	1	16	7,4 %	PT-08: 2 políticas VPD activas. PF-05: cada usuario ve su departamento.
CS9 · A8.5 Autenticación segura	1	15	6,9 %	PT-09: PERFIL_FUNCIONARIO cumple; 0 cuentas DEFAULT. PF-01: ORA-28000.
CS10 · A8.10 Eliminación de información	0,5	10	2,3 %	PT-10: 4 objetos de FIN en la papelera; retención RMAN de 14 días.
CS11 · A8.11 Enmascaramiento de datos	0,5	16	3,7 %	PT-11: 2 columnas sensibles sin redacción. PF-04: redacción en EMPLEADOS.
CS12 · A8.12 Prevención de fuga de datos	1	16	7,4 %	PT-12: keystore OPEN; tablespaces cifrados; exportación solo en cuentas autorizadas.
CS13 · A8.13 Respaldo de la información	0,5	10	2,3 %	PT-13: ARCHIVELOG, respaldo de 22/10 23:48, 12 piezas sin cifrar. PF-08: OK.
CS14 · A8.15 Registro (logging)	1	12	5,6 %	PT-14: 3 políticas activas, 3138 eventos en 7 días. PF-06: lecturas registradas.
CS15 · A8.20 Seguridad de redes	0	15	0,0 %	PT-15: sin adaptador de cifrado activo; sqlnet.ora sin parámetros de cifrado.
Total		216	**53,5 %**	

3. Hallazgos prioritarios y recomendaciones

Ordenados por el peso que el control deja de aportar al RC.

CS2 · A5.15 y CS7 · A8.2 (riesgo R-CONF-01, crítico)

Hallazgo: Cuatro privilegios otorgados directamente a usuarios, un SELECT sobre RRHH.EMPLEADOS otorgado a PUBLIC, SOPORTE01 con el rol DBA y APP_REPORTES con SELECT ANY TABLE.
Recomendación: Revocar el grant a PUBLIC y los privilegios directos, otorgarlos mediante roles por función, quitar el rol DBA a SOPORTE01 y reemplazar SELECT ANY TABLE por privilegios de objeto.

CS5 · A5.18 (R-CONF-01)

Hallazgo: No hay captura de privilegios ni acta de revisión de accesos.
Recomendación: Ejecutar DBMS_PRIVILEGE_CAPTURE durante un ciclo de trabajo y documentar una revisión trimestral.

CS15 · A8.20 (R-CONF-02)

Hallazgo: Las conexiones viajan sin cifrar y no se restringen los equipos que se conectan.
Recomendación: Definir SQLNET.ENCRYPTION_SERVER = REQUIRED y TCP.VALIDNODE_CHECKING con TCP.INVITED_NODES en sqlnet.ora.

CS6 · A5.33 (R-CONF-05)

Hallazgo: ADMIN_BD tiene DBA y AUDIT_ADMIN: puede alterar la auditoría de sus propias acciones.
Recomendación: Asignar AUDIT_ADMIN a una persona distinta del DBA.

CS1, CS3, CS10, CS11 y CS13 (cumplimiento parcial)

Hallazgo: 3 columnas sensibles sin etiquetar y 2 sin redacción, 2 cuentas abiertas que deberían estar bloqueadas, 4 objetos de FIN en la papelera y 12 piezas de respaldo sin cifrar.
Recomendación: Completar la clasificación y la redacción, bloquear CVARGAS y TEMP_SOPORTE, purgar la papelera y eliminar o volver a generar cifrados los respaldos antiguos.

4. Siguiente paso (ciclo PHVA)

Corregir los hallazgos (Actuar) y repetir los scripts sobre XEPDB1 (Verificar). La nueva evaluación E(Tres Patitos, XEPDB1, t2) se registra en la tabla de evaluaciones del artefacto, donde el gráfico muestra la variación del RC entre ambas fechas.

5. Anexos

- informe_evaluacion_TresPatitos_XEPDB1.txt: salida simulada del script, con el resultado de cada prueba.
- evidencia_verificacion_TresPatitos_XEPDB1.txt: salida simulada del script, con el resultado de cada prueba.
- evidencia_funcional_TresPatitos_XEPDB1.txt: salida simulada del script, con el resultado de cada prueba.

Referencias: ISO/IEC 27001:2022; ISO/IEC 27002:2022; Oracle Database 21c Security Guide y Database Reference; Ley 8968 de Protección de la Persona frente al Tratamiento de sus Datos Personales.